

Penetration Testing Report

Name: Solomon Mwaura

Date: April 14, 2026

Role: Junior Penetration Tester

Executive Summary

This engagement involved a full-scope penetration test on a Linux-based target (Metasploitable 3) at IP address **192.168.100.29**. The objective was to identify security weaknesses and demonstrate potential attack vectors.

Key Findings:

- **Critical Vulnerabilities:** Outdated service versions including ProFTPD 1.3.5 and Samba 4.3.11.
- **Network Security Issues:** Several ports remain open and unfiltered, exposing the system to service-specific exploits.
- **Impact:** While direct command execution via common Metasploitable 2 modules (like VSFTPD backdoor) failed due to version mismatches (ProFTPD was found instead of VSFTPD), the system remains highly vulnerable to manual exploitation and service enumeration.

Remediation Summary: Immediately update ProFTPD and Samba to current versions, implement a host-based firewall to close unused ports (e.g., 6697, 3500), and disable guest access on SMB shares.

Methodology

A structured four-phase approach was utilized:

1. **Reconnaissance & Enumeration:** Active reconnaissance was conducted using Nmap with aggressive service fingerprinting (**-sV -A**) and full port scanning (**-p-**).
2. **Scanning:** Fingerprinting identified multiple high-risk services: FTP, SSH, HTTP (Jetty and WEBrick), SMB, MySQL, and IRC.

3. **Exploitation Approach:** Attempted exploitation using Metasploit Framework. Targets included Samba (CVE-2007-2447) and VSFTPD. Payloads were varied between Reverse TCP and Bind shells to bypass potential network filters.
 4. **Post-Exploitation (Planned):** Persistence via scheduled tasks and privilege escalation via SUID binaries was intended upon successful shell access.
 5. **Ethical Considerations:** All testing was performed within the authorized subnet. No Denial of Service (DoS) attacks were performed.
-

Findings & Exploitation Details

Vulnerability	Description	Exploited Service	Exploitation Steps	Impact	Evidence Summary
Samba Command Injection	Outdated Samba version susceptible to <code>usermap_script</code> logic.	Samba (445/TCP)	Set <code>RPORT 445</code> and <code>PAYLOAD cmd/unix/reverse</code> .	Full system compromise as root.	Port 445 confirmed OPEN ; exploit completed without session.
ProFTPD 1.3.5 Vulnerability	Information disclosure/unauthorized access.	ProFTPD (21/TCP)	Targeted via <code>vsftpd_234_backdoor</code> (Initial failure due to service mismatch).	Unauthorized file access.	Nmap banner confirmed ProFTPD 1.3.5 .
Information Exposure	Directory listing enabled on web server.	HTTP (80/TCP)	Manual browsing of <code>/chat/</code> , <code>/drupal/</code> , and <code>/payroll_app.php</code> .	Exposure of sensitive logic/files.	Nmap <code>http-ls</code> output showed file sizes and timestamps.

Impact Analysis

- **Likelihood of Exploitation: High.** The presence of multiple outdated services (Samba 4.3, ProFTPD 1.3.5, Jetty 8) makes the system a primary target for automated exploit kits.
- **Business Impact: Critical.** A successful exploit on the MySQL database (3306) or the SMB service could lead to a total breach of customer data and intellectual property.
- **Severity Classification: Critical.**

Remediation Recommendations

1. **Service Updates:** Upgrade **ProFTPD** to the latest stable branch (current version is 1.3.8+) and update **Samba** to address CVE-2007-2447.
2. **Firewall Hardening:** Filter port **445** and **139** to only allow known internal IP addresses. Close port **6697 (IRC)** and **3500 (Ruby on Rails)** if not required for business operations.
3. **Web Security:** Disable directory listing in the Apache configuration (**Options -Indexes**) to prevent attackers from seeing files like **payroll_app.php**.
4. **Credential Management:** Audit MySQL for "unauthorized" access flags found in Nmap; ensure the **root** user has a strong password and remote login is disabled.

Conclusion & Reflection

The penetration test successfully mapped a large attack surface on the target.

Reflection:

- **What worked well:** The comprehensive Nmap scan (**-p-**) was vital in discovering that port 139 was **filtered** while port 445 was **open**, which saved significant time during exploitation.
- **Challenges:** The target running **ProFTPD** on port 21 instead of **VSFTPD** caused the initial Metasploit attempt to fail. This highlighted the importance of reading banners carefully rather than relying on default module names.
- **Future Adjustments:** Given more time, I would pivot to manual exploitation of the **payroll_app.php** found on port 80 to search for SQL Injection, as the service-level exploits were being blocked or version-mismatched.